Vibe-Audit · Rapport de Sécurité Express

AUDIT PASSIF & REMÉDIATION IA ASSISTÉE · ÉCHANTILLON DE VALIDATION

Application : **LeadFlow SaaS (v1.4)**
Date : **14 Octobre 2026**
Auditeur : **Kreesten Agboton**
Cadre légal : **Consentement écrit n° 2026-10-A4**

SYNTHÈSE DES CONSTATS RÉELS CONFIRMÉS

Total : 4 constats · 4 contrôles validés

2 Élevés	1 Moyen	1 Faible	4 Contrôles Sécurisés

SYNTHÈSE EXÉCUTIVE DÉCIDEUR

L'audit passif de l'application **LeadFlow** a identifié deux vulnérabilités d'importance élevée permettant l'extraction non authentifiée de données clients et l'exposition d'une clé d'intégration.

Aucune intrusion active n'a été opérée. L'infrastructure de paiement Stripe et la gestion des sessions utilisateurs sont saines. Les correctifs proposés ci-après peuvent être appliqués en moins d'une heure sans refonte d'architecture.

COUVERTURE DU PÉRIMÈTRE

Composant	Méthode	Statut
Supabase RLS (Orders)	Recherche passive REST	Constat Élevé
Bundles JS / Clés API	Inspection statique AST	Constat Élevé
Gestion des Sessions Auth	Vérification JWT & cookies	Sécurisé
Infrastructure Stripe	Non testé (hors périmètre)	Hors périmètre

3 ACTIONS PRIORITAIRES IMMÉDIATES

1. **Activer la politique RLS sur la table des commandes (SEC-01)**
   Bloque l'accès public immédiat aux emails et montants des transactions (Détail page 2).
2. **Déplacer la clé secrète Resend vers une Edge Function (SEC-02)**
   La clé API présente dans le build client permettait l'usurpation de vos envois de mails.
3. **Durcir les en-têtes HTTP de sécurité (SEC-03)**
   Ajout de Content-Security-Policy et X-Frame-Options contre le détournement de clics.

Kit de remédiation : Chaque constat en page 2 est accompagné d'un prompt prêt à coller dans votre assistant (Lovable, Bolt, Cursor) avec ses critères de vérification.

GRAVITÉ : ÉLEVÉ

Constat confirmé

SEC-01 : Absence de Row Level Security (RLS) sur la table des commandes

`supabase/schema:orders`

1. IMPACT MÉTIER & CONSÉQUENCE

Fuite de données transactionnelles clients

La table `orders` est accessible en lecture directe sans filtrage par utilisateur. Tout visiteur non authentifié connaissant l'URL Supabase publique peut télécharger l'historique complet des commandes, adresses emails et montants encaissés.

2. PREUVE TECHNIQUE REPRODUCTIBLE

REQUÊTE CURL PASSIVE NON INTRUSIVE — STATUT : 200 OK

```
# Requête passive effectuée sans jeton utilisateur
curl -s "https://app.leadflow.io/rest/v1/orders?
select=id,customer_email,amount" \
  -H "apikey: eyJhbGciOiJIUzI1NiIsInR5cCI***"

# Données sensibles retournées en clair (échantillon masqué) :
[
  { "id": "ord_812", "customer_email": "m.***@gmail.com", "amount":
4900 },
  { "id": "ord_813", "customer_email": "agence.***@pro.fr",
"amount": 12900 }
]
# Constat : 142 enregistrements accessibles publiquement
```

3. REMÉDIATION IMMÉDIATE

Correction proposée

Cible : Lovable / Bolt / Cursor / Supabase SQL — Prompt prêt à coller

```
Dans la configuration de la base de données Supabase, active la politique
Row Level Security (RLS) sur la table `orders`.

Applique la politique stricte d'isolation suivante :
ALTER TABLE orders ENABLE ROW LEVEL SECURITY;

CREATE POLICY "Utilisateur consulte ses propres commandes"
ON orders FOR SELECT
USING (auth.uid() = user_id);

CREATE POLICY "Utilisateur insère uniquement pour son compte"
ON orders FOR INSERT
WITH CHECK (auth.uid() = user_id);

Valide que les requêtes anonymes sans jeton d'authentification sont
désormais rejetées.
```

4. Critères de Validation Post-Correction

- **Test 1 :** Exécuter à nouveau la commande curl ci-contre. Le serveur doit renvoyer un tableau vide `[]` ou une erreur `401 Unauthorized`.
- **Test 2 :** Se connecter sur l'interface avec un compte client : vérifier que ses commandes personnelles restent visibles sans interruption.
- **Re-contrôle :** Éligible au protocole de contre-vérification J+14 (inclus sur demande après déploiement).